Lab 5: Static Code Analysis

Report for **energy_system.py** (Energy Consumption & Tariff Calculator), repository **L5_03_energy_tariff**

Tool	Before	After
Pylint	6.14 / 10	10.00 / 10
Bandit	1 issue (Medium severity, High confidence)	No issues identified
Flake8	12 warnings	0 warnings

1. Objective and setup

Use Pylint, Bandit and Flake8 to find, document and fix quality, security and style problems in the assigned Python script, as described in the Lab 5 student handout.

Environment: Python virtual environment (`python3 -m venv venv`, `source venv/bin/activate`) with `pip install pylint bandit flake8`.

2. Step 1: Inspect and run the program

The program records meter readings, computes an electricity bill, flags meters with high usage and saves readings to `meters.json`. The original starter (commit 24e2bcb) was run with `python energy_system.py`, pressing Enter at the prompt:

Output of the original starter

```
Readings stored so far: 3
Bill M-01: 495.00
Bill M-03: -192.50
Spikes: ['M-02']
Extra units for M-01 as an expression (Enter for 0): Bill M-01 after reload: 495.00
```

The starter already shows output that looks wrong: meter M-03 receives a negative reading (-50) and gets a negative bill.

3. Step 2: Static analysis reports (before)

Commands run against the starter: `pylint energy_system.py > pylint_report.txt`, `bandit -r energy_system.py > bandit_report.txt`, `flake8 energy_system.py > flake8_report.txt`. The reports are in the repository folder `before/` and are reproduced unchanged below.

before/pylint_report.txt

```
************* Module energy_system
energy_system.py:1:0: C0114: Missing module docstring (missing-module-docstring)
energy_system.py:12:0: C0116: Missing function or method docstring (missing-function-docstring)
energy_system.py:12:0: W0102: Dangerous default value [] as argument (dangerous-default-value)
energy_system.py:17:0: C0116: Missing function or method docstring (missing-function-docstring)
energy_system.py:19:4: R1705: Unnecessary "elif" after "return", remove the leading "el" from "elif" (no-else-return)
energy_system.py:26:0: C0116: Missing function or method docstring (missing-function-docstring)
energy_system.py:27:4: W0603: Using the global statement (global-statement)
energy_system.py:32:0: C0116: Missing function or method docstring (missing-function-docstring)
energy_system.py:39:0: C0116: Missing function or method docstring (missing-function-docstring)
energy_system.py:40:4: W0603: Using the global statement (global-statement)
energy_system.py:44:4: W0702: No exception type(s) specified (bare-except)
energy_system.py:42:12: W1514: Using open without explicitly specifying an encoding (unspecified-encoding)
energy_system.py:42:12: R1732: Consider using 'with' for resource-allocating operations (consider-using-with)
energy_system.py:47:0: C0116: Missing function or method docstring (missing-function-docstring)
energy_system.py:48:8: W1514: Using open without explicitly specifying an encoding (unspecified-encoding)
energy_system.py:48:8: R1732: Consider using 'with' for resource-allocating operations (consider-using-with)
energy_system.py:52:0: C0116: Missing function or method docstring (missing-function-docstring)
energy_system.py:59:10: C0209: Formatting a regular string which could be an f-string (consider-using-f-string)
energy_system.py:60:10: C0209: Formatting a regular string which could be an f-string (consider-using-f-string)
energy_system.py:63:27: W0123: Use of eval (eval-used)
energy_system.py:66:10: C0209: Formatting a regular string which could be an f-string (consider-using-f-string)
energy_system.py:2:0: W0611: Unused import sys (unused-import)

-------------------------------------------------------------------
Your code has been rated at 6.14/10 (previous run: 6.14/10, +0.00)
```

before/bandit_report.txt

```
Run started:2026-10-15 05:25:09.929578

Test results:
>> Issue: [B307:blacklist] Use of possibly insecure function - consider using safer ast.literal_eval.
   Severity: Medium   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.8.6/blacklists/blacklist_calls.html#b307-eval
   Location: ./energy_system.py:63:27
62■    adjustment = input("Extra units for M-01 as an expression (Enter for 0): ") or "0"
63■    record_reading("M-01", eval(adjustment))
64■    save_meter_data()

--------------------------------------------------

Code scanned:
■Total lines of code: 58
■Total lines skipped (#nosec): 0
■Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
■Total issues (by severity):
■■Undefined: 0
■■Low: 0
■■Medium: 1
■■High: 0
■Total issues (by confidence):
■■Undefined: 0
■■Low: 0
■■Medium: 0
■■High: 1
Files skipped (0):
```

before/flake8_report.txt

```
energy_system.py:2:1: F401 'sys' imported but unused
energy_system.py:12:1: E302 expected 2 blank lines, found 1
energy_system.py:17:1: E302 expected 2 blank lines, found 1
energy_system.py:24:80: E501 line too long (88 > 79 characters)
energy_system.py:26:1: E302 expected 2 blank lines, found 1
energy_system.py:32:1: E302 expected 2 blank lines, found 1
energy_system.py:39:1: E302 expected 2 blank lines, found 1
energy_system.py:44:5: E722 do not use bare 'except'
energy_system.py:47:1: E302 expected 2 blank lines, found 1
energy_system.py:52:1: E302 expected 2 blank lines, found 1
energy_system.py:62:80: E501 line too long (86 > 79 characters)
energy_system.py:68:1: E305 expected 2 blank lines after class or function definition, found 1
```

4. Step 3: Identified issues

Findings are ordered by severity (security and bugs first). Line numbers refer to the original starter file.

Issue	Type	Line(s)	Description	Fix approach
eval() on user input (Bandit B307, Pylint W0123)	Security (Medium)	63	eval(adjustment) executes whatever the user types, allowing arbitrary code execution.	Replaced with ast.literal_eval(), wrapped in try/except (ValueError, SyntaxError) so invalid input prints a message.
Mutable default argument history=[] (Pylint W0102)	Bug	12	The default list is created once and shared across all calls.	Removed the shared history parameter; readings are stored per meter in a dict of lists.
Bare except (Pylint W0702, Flake8 E722)	Bug / bad practice	44	Catches every exception and silently resets the data to {}.	Catch only json.JSONDecodeError and check os.path.exists() for a missing file.
File opened without with (Pylint R1732)	Resource leak	42, 48	The file handle is not closed if an error occurs before close().	Used with open(...) as file_obj.
open() without encoding (Pylint W1514)	Portability	42, 48	Default encoding depends on the operating system.	Added encoding="utf-8".
global statements (Pylint W0603)	Design	27, 40	Functions rebind module state with global.	Removed global; functions mutate the shared meter_data dict.
Unused import sys (Flake8 F401, Pylint W0611)	Style	2	Imported but never used.	Removed the import.
Missing docstrings (Pylint C0114, C0116)	Documentation	1, 12, 17, 26, 32, 39, 47, 52	Module and all functions have no docstring.	Added a module docstring and one-line function docstrings.
Unnecessary elif after return (Pylint R1705)	Style	19	elif after return is redundant.	Simplified the billing logic.
% string formatting (Pylint C0209)	Style	59, 60, 66	Old-style string formatting.	Converted to f-strings.
Blank-line spacing (Flake8 E302, E305)	Style (PEP 8)	12, 17, 26, 32, 39, 47, 52, 68	Two blank lines required around top-level definitions.	Reformatted.
Lines too long (Flake8 E501)	Style (PEP 8)	24, 62	Lines of 88 and 86 characters exceed 79.	Wrapped the long lines.

5. Step 4: Fixes

Fixes were committed to Git. Commit hashes below are from the repository history.

Commit	Message	Addresses
b2e2e07	Fix Bandit security issue B307 by using ast.literal_eval	Bandit: eval() replaced; also reduced Flake8 from 12 to 10 warnings
94bf530	Fix Pylint code quality issues and raise score above 9.5	Pylint fixes (docstrings, with open, encoding, f-strings, bare except); Flake8 down to 1 warning
c1a795e	Fix final newline	Last Flake8 warning (W292) and last Pylint message (C0304); Pylint reaches 10.00
4d0bf0d	Regenerate after reports	Final after/ reports regenerated from the finished code

Fix for the Bandit issue (the exact change made at the prompt):

```
# before
record_reading("M-01", eval(adjustment))

# after
try:
    record_reading("M-01", ast.literal_eval(adjustment))
except (ValueError, SyntaxError):
    print("Invalid input; no adjustment recorded.")
```

6. Verification (after)

Final energy_system.py runs without errors (Enter pressed at the prompt)

```
Readings stored so far: 1
Readings stored so far: 2
Readings stored so far: 3
Readings stored so far: 1
Readings stored so far: 2
Readings stored so far: 1
Bill M-01: 2475.00
Bill M-03: -962.50
Spikes: ['M-01']
Extra units for M-01 as an expression (Enter for 0): Readings stored so far: 4
Bill M-01 after reload: 2475.00
```

All three tools were re-run on the final file and the reports saved in `after/`:

after/pylint_report.txt

```
--------------------------------------------------------------------
Your code has been rated at 10.00/10 (previous run: 10.00/10, +0.00)
```

after/bandit_report.txt

```
Run started:2026-10-15 06:25:44.612601

Test results:
■No issues identified.

Code scanned:
■Total lines of code: 57
■Total lines skipped (#nosec): 0
■Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
■Total issues (by severity):
■■Undefined: 0
■■Low: 0
■■Medium: 0
■■High: 0
■Total issues (by confidence):
■■Undefined: 0
■■Low: 0
■■Medium: 0
■■High: 0
Files skipped (0):
```

after/flake8_report.txt

```
(empty file: Flake8 reported no warnings)
```

Handout requirement (Step 4)	Result
Handle all issues reported by Bandit	Met: 1 issue to 0
Pylint score above 9.5	Met: 6.14 to 10.00
Handle all formatting issues raised by Flake8	Met: 12 to 0
Rerun the tools and confirm fixes	Done; reports in after/

7. Deliverables checklist

Handout deliverable	Where
Cleaned version with at least four issues fixed	energy_system.py (12 issue groups fixed)
Table documenting issues and fixes	Section 4 of this report
pylint, bandit and flake8 reports, before and after	before/ and after/ folders
Commits for fixes raised by the three tools	Section 5 (Bandit and Pylint have their own commits; Flake8 fixes are spread across them and the final commit)

8. Note on program behaviour

Running the final file with the same inputs gives different numbers from the starter (for example Bill M-01 is 2475.00 instead of 495.00, and the spike check flags M-01 instead of M-02), because the billing and spike logic were rewritten during the cleanup. Negative readings, such as -50 for M-03, are still accepted. These are logic differences, not tool findings, and are listed here for completeness.